ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Emerson (GE) PACSystems RX3i Controller (CPE/CPL series) · Component type: **Embedded Device (EDR) - PLC/PAC** · Target SL = SL 3

Where to work	**PAC Machine Edition (PME)**: controller **access-control levels** (privilege levels 1-4) + passwords, **OEM protection**, port/protocol configuration, **OPC UA** server security, firmware update (WinLoader / PME). Follow the Emerson **PACSystems Secure Deployment Guide (SDG)**. Confirm **TPM** and signed-firmware support.
Interfaces / ports	Embedded Ethernet (SRTP, EGD, Modbus/TCP), **OPC UA** server, optional Ethernet modules; PROFINET; serial. CPE300/CPE400/CPL410 series RX3i. Engineer via PME.
Notes	EDR (embedded controller) - Emerson (formerly GE) PACSystems RX3i. Confirm CPU model/firmware and whether TPM + digitally-signed/encrypted firmware and OPC UA security are present; older CPUs lean more on compensating segmentation.
How to read	Read-only: review the PME target properties, access-control/passwords, port config, and OPC UA security. Native how-to + external-tool validation + pass. Scans authorized; fuzz/exploit only in an isolated/lab environment with written authorization.

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device's own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): the PAC (Proficy) Machine Edition project **backup (.zip)** and an **upload from the controller**, the access-control level (1-4) + password & OEM-protection settings, the OPC UA server security + port/protocol config, firmware rev (WinLoader), and the controller + I/O fault tables.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user identification & auth	In PME › controller **Access Control**, set passwords on the privilege levels so configuration/logic changes require authentication; enable the highest appropriate protection so no unauthenticated write/download is possible. **Ext. tools:** PME (access-control / password review); attempt anonymous download (isolated).	Access requires authentication; privilege-level passwords set; no anonymous config.	
SR/CR 1.2	Software process / device identification	Confirm the controller and each comm partner (HMI, SCADA, engineering) are uniquely identified (IP / SRTP / OPC UA endpoint, name) and mutually configured; OPC UA binds partners by certificate. **Ext. tools:** PME (target/partner config); Wireshark (partner identity).	Unique device identity; comm partners identified/bound.	
SR/CR 1.3	Account management	Manage the privilege-level passwords and any OPC UA/engineering credentials (create/change/remove); use **OEM protection** to lock proprietary logic; no shared/default passwords; least-privilege access. **Ext. tools:** PME (access-control + OEM protection review).	Passwords/credentials managed; OEM protection where needed; defaults changed.	
SR/CR 1.4	Identifier management	Confirm unique user credentials (OPC UA users) and a unique controller identity (IP, name, serial); no reuse across controllers. **Ext. tools:** PME; network inventory.	Unique user and device identifiers; no reuse.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.5	Authenticator management	Per the Emerson SDG, use long (12+ character) complex passwords for all privilege levels and OPC UA users; change all defaults; manage lifecycle. Do not store passwords in shared PME projects unprotected. **Ext. tools:** PME password review; SDG conformance check.	Strong (12+ char) passwords; no defaults; managed lifecycle.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	PKI certificates	For the **OPC UA** server (and any HTTPS), confirm device/application certificates are CA-issued (asset-owner PKI), valid, and not default self-signed; manage the trust list. **Ext. tools:** OPC UA client (cert view); openssl.	CA-issued, valid OPC UA certificates; defaults replaced.	
SR/CR 1.9	Strength of public key auth	Confirm OPC UA uses a strong security policy (Basic256Sha256+) and TLS; no weak/expired certs. Legacy protocols (SRTP/EGD/Modbus) have no crypto and rely on the segmented zone. **Ext. tools:** OPC UA client (security policy); testssl.sh (if HTTPS).	Strong OPC UA crypto; legacy protocols compensated by segmentation.	
SR/CR 1.10	Authenticator feedback	Confirm PME and any OPC UA/web login mask password entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm repeated failed access attempts are rejected/throttled and, where OPC UA is used, lockout applies; monitor failed-auth via SIEM. **Ext. tools:** PME/OPC UA lockout test (isolated); SIEM failed-auth events.	Failed logins rejected/throttled; attempts monitored.	
SR/CR 1.12	System use notification	No native controller banner; enforce the approved use-notification on the PME engineering workstation and HMI (compensating). **Ext. tools:** EWS/HMI banner review.	Approved use notice at EWS/HMI (compensating at controller).	Compensating.
SR 1.13	Access via untrusted networks	Confirm the controller is reachable only from the trusted cell zone behind a firewall / managed switch ACLs; remote engineering via VPN; deny SRTP/OPC UA/Modbus from untrusted networks. **Ext. tools:** Nmap (from untrusted side); firewall/ACL review.	Access from untrusted networks denied/brokered; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Confirm the access-control privilege levels enforce read vs write vs config; program download/mode change requires the appropriate password; **OEM protection** blocks viewing/altering protected logic. **Ext. tools:** PME (privilege-level review); attempt unauthorized download (isolated).	Least-privilege enforced; download/config requires authorization.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control the CPU energy-pack/SD/USB and the engineering laptop; removable-media policy on the EWS; only authorized PME projects/firmware loaded. **Ext. tools:** Physical inspection; EWS media policy.	Portable/engineering media controlled.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code on the controller; confirm only the compiled PME application and signed firmware run; no untrusted code path (C-blocks, if used, are reviewed/controlled). **Ext. tools:** PME (program / C-block review).	Only the trusted compiled application runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm engineering/OPC UA sessions time out on inactivity and require re-authentication; PME connection returns to a non-privileged state after timeout. **Ext. tools:** PME/OPC UA timeout config.	Sessions lock/timeout on inactivity; re-auth required.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.6	Remote session termination	Confirm engineering/OPC UA sessions can be terminated and idle sessions close; the access configuration limits who can reconnect. **Ext. tools:** PME (connection status); Wireshark.	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	Confirm concurrent programming/OPC UA connections are bounded and monitored; reservation prevents conflicting simultaneous programming. **Ext. tools:** PME connection review; OPC UA server limits.	Concurrent privileged sessions limited/monitored.	
SR/CR 2.8	Auditable events	Confirm security-relevant events (auth, config/mode change, firmware) are captured (controller fault tables / OPC UA audit) and forwarded via **Syslog** to the SIEM with an attributable identity. **Ext. tools:** PME fault tables; Syslog/SIEM review.	Security events logged, forwarded, and attributable.	
SR/CR 2.9	Audit storage capacity	The controller fault tables are finite; forward events to the SIEM for retention; confirm sizing and threshold alerting. **Ext. tools:** Syslog/SIEM retention review.	Events offloaded and retained; alert before capacity.	
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM alerts if controller event forwarding fails; local fault tables continue so events are not silently lost. **Ext. tools:** SIEM agent-health / syslog-gap alert.	Audit-failure alerting defined.	
SR/CR 2.11	Timestamps	Confirm the controller time is synced (SNTP/NTP) to the plant time source so fault-table and SIEM timestamps are accurate and correlate. **Ext. tools:** PME (time sync); NTP server check.	Reliable, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control the CPU physical interfaces: the **RUN/STOP** switch, SD/USB, serial/console, and energy pack; keep the CPU in a locked panel; disable unused Ethernet services and protocols. **Ext. tools:** Physical inspection; PME (disabled-service review).	Physical/diagnostic interfaces controlled; unused services disabled.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	Use **OPC UA** sign+encrypt for controller-to-SCADA integrity+confidentiality where supported; segment SRTP/EGD/Modbus (which are unauthenticated) inside the cell zone; avoid cleartext control protocols across boundaries. **Ext. tools:** Wireshark (OPC UA vs cleartext SRTP/Modbus); OPC UA policy.	OPC UA integrity/confidentiality where supported; legacy contained to the zone.	
SR/EDR 3.2	Protection from malicious code (component)	Confirm only Emerson digitally-signed & encrypted firmware runs and the controller rejects unsigned images; OEM protection preserves logic integrity; no arbitrary code path. **Ext. tools:** PME/WinLoader (firmware signature); Emerson advisory checksum.	Only signed firmware/authorized logic runs; component protected.	EDR-specific.
SR/CR 3.3	Security functionality verification	After any change, re-verify access-control levels, OEM protection, disabled services, OPC UA security, and enhanced-security settings against the SDG baseline; compare the PME project. **Ext. tools:** PME (compare to baseline); Nmap (confirm unused services off).	Security settings match the SDG hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Confirm program/config integrity: OEM protection + password-protected download, baseline the PME project, and change detection so unauthorized logic/config changes are prevented/detected. **Ext. tools:** PME (OEM protection); online-vs-offline compare.	Program integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Confirm the controller tolerates malformed SRTP/EGD/Modbus/OPC UA frames without faulting. **ISOLATED only:** fuzz the protocol interfaces on a representative CPU and watch scan/connection health. **Ext. tools:** Protocol fuzzer / traffic generator (ISOLATED); Wireshark.	No crash or loss of control on malformed input.	Do NOT fuzz production.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.6	Deterministic output	Verify configured fail-safe behavior: output-module default/hold state on CPU STOP or comm loss, and the CPU behavior on fault, so outputs assume a defined safe state. **Ext. tools:** PME (I/O default/hold-last-state config review).	Outputs go to a defined/fail-safe state on fault or comm loss.	
SR/CR 3.7	Error handling	Confirm graceful fault handling (I/O and controller fault tables, defined fault response) without loss of control or info leakage. **Ext. tools:** PME (fault tables / fault response review).	Graceful fault handling; no crash, unsafe state, or info leak.	
SR/CR 3.8	Session integrity	Where OPC UA (sign+encrypt) is applied, sessions are integrity-protected against replay/hijack; confirm secured channels in use; legacy sessions contained by the zone. **Ext. tools:** Wireshark (session inspection).	Sessions integrity-protected where supported; contained otherwise.	
SR/CR 3.9	Protection of audit information	Protect event transport (Syslog over TLS where supported) and the SIEM store; restrict who can read/clear controller fault tables. **Ext. tools:** SIEM access review; syslog transport check.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Update firmware only with Emerson digitally-signed & encrypted firmware via PME/WinLoader; the CPU validates the image; plan controlled updates with rollback to a prior signed revision. **Ext. tools:** PME/WinLoader (signed update / verify); Emerson advisory check.	Signed firmware updates only, with a controlled update + rollback path.	EDR-specific.
EDR 3.11	Physical tamper resistance/detection	Keep the CPU in a locked, sealed panel; RUN/STOP switch and SD/USB/energy-pack controlled; fault tables / OPC UA audit record config/firmware changes as tamper evidence. **Ext. tools:** Physical inspection; fault-table / audit review.	Enclosure locked/sealed; interfaces controlled; changes logged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	The CPU accepts only Emerson-signed firmware (product-supplier root of trust); confirm the signing chain is intact and unsigned/altered firmware is rejected at load. **Ext. tools:** PME/WinLoader (signature verify); attempt unsigned image (isolated) -> rejected.	Supplier signing root intact; unsigned/altered firmware rejected.	EDR-specific.
EDR 3.13	Provisioning asset-owner roots of trust	For OPC UA, confirm the asset owner can provision/manage its own certificates and trust list (asset-owner PKI); else record the compensating control. **Ext. tools:** OPC UA certificate/trust-list review.	Asset-owner certificate provisioning supported/verified, or compensating recorded.	EDR-specific.
EDR 3.14	Integrity of the boot process	Confirm the CPU validates signed-firmware integrity before execution (TPM-backed secure boot where present); no unsigned/tampered firmware runs. Capture firmware version/status. **Ext. tools:** PME (firmware version/signature); TPM/secure-boot status.	Firmware integrity validated before execution; only signed firmware boots.	EDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, clear the controller program/memory and reset to defaults, and sanitize/destroy any SD/energy-pack-retained data so program and configuration are not recoverable. **Ext. tools:** PME (clear controller); media sanitize.	Sensitive program/config purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto for OPC UA / any HTTPS (TLS 1.2/1.3, Basic256Sha256+); disable legacy unauthenticated services where feasible; certificates managed. **Ext. tools:** OPC UA policy; testssl.sh (if HTTPS).	Modern crypto where supported; legacy services disabled where feasible.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	Confirm the controller sits in a controlled cell/zone behind a firewall / managed-switch ACLs; only required protocols (OPC UA/SRTP/Modbus/PROFINET) cross the boundary; no flat convergence with IT. **Ext. tools:** Nmap by zone; firewall/ACL rule review.	Controller in a segmented zone; only required flows cross the boundary.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Embedded controller with no general-purpose person-to-person communications (email/IM/web). **Ext. tools:** Confirm no such services on the controller.	N/A - justification recorded (single-purpose embedded device).	N/A
SR 5.4	Application partitioning	**N/A.** Single-purpose controller; no separable applications to partition (handled at the SCADA/host layer). **Ext. tools:** Confirm single-function device.	N/A - justification recorded.	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm fault tables / OPC UA audit and diagnostics are readable/exportable and forwarded (Syslog) to the SIEM for continuous monitoring; the cell is passively monitored (OT IDS). **Ext. tools:** Syslog listener; passive OT IDS (mirror port).	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: the CPU connection-resource limits and cell-firewall rate-limiting prevent a flood from denying control; monitor scan time and connection load. **Ext. tools:** PME (connection/scan load); traffic generator (ISOLATED).	Resources bounded; control continues under load.	
SR/CR 7.2	Resource management	Confirm the CPU limits resource exhaustion (max connections, communications load, scan monitoring) so a single service cannot starve control. **Ext. tools:** PME (comms load / scan monitoring).	Resources bounded; no exhaustion-based loss of control.	
SR/CR 7.3	Control system backup	Confirm the PME project + controller configuration are backed up (versioned, offline) and restore/recovery is tested so the CPU can be rebuilt to a known-good state. **Ext. tools:** Backup repository review; restore test (lab).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Confirm hardening per the Emerson SDG: enable enhanced/secure mode, disable unused protocols/services (unused Ethernet ports, EGD/Modbus if not required, web), restrict OPC UA endpoints. **Ext. tools:** PME (service config); Nmap (exposed services).	Least functionality; unused services disabled per the SDG baseline.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm the CPU (model, firmware, modules, PME version) is inventoried so vulnerabilities track against Emerson security advisories. **Ext. tools:** ReadOnlyEnum; PME device/firmware inventory.	Accurate component/firmware inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
PAC Machine Edition (PME)	Native config & protection review (all FRs)	Read access-control levels/passwords, OEM protection, port/protocol config, OPC UA security, fault tables, and firmware; compare to the SDG baseline.	Read/authorized project copy.
Emerson Secure Deployment Guide (SDG)	Hardening baseline reference (1.5/1.7, 3.3, 7.6)	Confirm password strength, enhanced-security mode, and disabled-service guidance are applied.	Reference document.
Nmap / ReadOnlyEnum	Exposed-service & zone enumeration (1.13, 5.x, 7.6, 7.8)	Enumerate SRTP/OPC UA/Modbus/web from each zone; confirm only required services reachable.	Read-only; authorized.
OPC UA client / testssl.sh	OPC UA & TLS strength (1.8, 1.9, 4.3)	Check the OPC UA security policy (Basic256Sha256+) and any HTTPS TLS ciphers.	Non-intrusive.
Wireshark	Comms integrity review (3.1, 3.8)	Confirm OPC UA channels are encrypted+authenticated; legacy SRTP/Modbus contained to the zone.	Passive capture.
Protocol fuzzer / traffic generator	Input validation & DoS resilience (3.5, 7.1)	Malformed-frame / high-rate testing on a bench CPU while watching scan/connection health.	ISOLATED/non-production; written authorization.
Syslog listener + SIEM	Event forwarding & monitoring (2.8-2.10, 6.x)	Confirm controller security events reach the SIEM; trigger a test auth/config event.	Coordinate with SIEM team.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.